

Term	Definition	Source
Resilience	The ability to prepare for and adapt to changing conditions and withstand and recover rapidly from disruptions. Resilience includes the ability to withstand and recover from deliberate attacks, accidents, or naturally occurring threats or incidents.	NIST Glossary
Role-based access	A model for controlling access to resources where permitted actions on resources are identified with roles rather than with individual subject identities.	NIST Glossary
Rollback	Updates to earlier firmware versions may provide a means to recover from a firmware update that is not functioning correctly.	NIST SP 800-193, Platform Firmware Resiliency Guidelines
	A means to recover from an update that is not functioning correctly or restore to a previous secure and functional version that may require the physical presence of a user.	FFIEC Adapted for Supervisory Purposes
Runtime	The period during which a computer program is executing.	NIST Glossary
S		
Sanitization	Actions taken to render data written on media unrecoverable by ordinary and, for some forms of sanitization, extraordinary means.	NIST Glossary
Scalability	Refers to how well a hardware and software system can adapt to increased demands. For example, a scalable network system would be one that can start with just a few nodes but can easily expand to thousands of nodes. Scalability can be a very important feature because it means the entity can invest in a system with confidence that the entity will not quickly outgrow it.	FFIEC Developed for Supervisory Purposes
Scheduling	A method used in the information processing facility to determine and establish the sequence of computer job processing.	ISACA Glossary
Scope creep	Also referred to as requirement creep, this refers to uncontrolled changes in a project's scope. Scope creep can occur when the scope of a project is not properly defined, documented, and controlled. Typically, the scope increase consists of either new products or new features of already approved products. Hence, the project team drifts away from its original purpose. Because of one's tendency to focus on only one dimension of a project, scope creep can also result in a project team overrunning its original budget and schedule. For example, scope creep can be a result of poor change control, lack of proper identification of what products and features are required to bring about the achievement of project objectives in the first place, or a weak project manager or executive sponsor.	ISACA Glossary
	Scope creep refers to uncontrolled changes in a project's scope, adding features and functionality without addressing the effects on time, costs, and resources. These changes may result from a lack of effective project change management, without approval (e.g., management or customer), or when the scope is not properly defined, documented, and controlled.	FFIEC Adapted for Supervisory Purposes
Secure code review	The process of auditing the source code of an application to verify that the proper security and logical controls are present, that they work as intended, and that they have been invoked in the right places. Code review aims to identify security flaws in the application related to its features and design, along with the exact root causes.	OWASP, Code Review Guide 2.0
	The process of auditing the source code of an application to verify that the proper security and logical controls are present, work as intended, and have been invoked in the right places.	FFIEC Adapted for Supervisory Purposes
Secure development	A hardware and software development approach with an objective of building systems and components while minimizing the potential for vulnerabilities and reducing the attack surface. This is done through measures such as secure coding practices, comprehensive development testing, and built-in security mechanisms (e.g., access control, authentication, and logging capabilities).	FFIEC Developed for Supervisory Purposes
Security	The state in which the integrity, confidentiality, and accessibility of information, service or network entity is assured.	NIST Glossary

Term	Definition	Source
Security impact analysis	The analysis conducted by qualified staff in an organization to determine the extent to which changes to the system affect the security posture of the system.	NIST 800-128, Guide for Security-Focused Configuration Management of Information Systems
Security testing	Testing that attempts to verify that an implementation protects data and maintains functionality as intended.	NIST Glossary
	Testing that attempts to verify that a modified or new system implementation includes appropriate controls and does not introduce any security holes that might compromise other systems or allow for any misuse of the system or its information and protects data and maintains functionality as intended.	FFIEC Adapted for Supervisory Purposes
Server	A computer or device on a network that manages network resources. Examples include file servers (to store files), print servers (to manage one or more printers), network servers (to manage network traffic), and database servers (to process database queries).	NIST Glossary
Service deregistration	Removal of a service from the service registry.	FFIEC Developed for Supervisory Purposes
Service discovery	The process by which an application learns what services are available on the network, and by which the network learns what services the application can provide.	Science Direct Topics in Computer Science
Service improvement	The actions taken to identify and execute methods to improve an entity's services and align them with its business objectives.	FFIEC Developed for Supervisory Purposes
Service level agreement (SLA)	Defines the specific responsibilities of the service provider and sets the customer expectations.	NIST Glossary
	A formal agreement between two parties that records a common understanding about products or services to be delivered, priorities, responsibilities, guarantees, and warranties between the parties. In addition, the agreement describes the nature, quality, security, availability, scope, and timeliness of delivery and response of the parties, the point(s) of contact for end-user problems, and the metrics by which the effectiveness of the process is monitored and approved and may include other measurable objectives. The agreement should cover not only expected day-to-day situations, but also unexpected or adverse events, as the need for the service may vary.	FFIEC Adapted Definition for Supervisory Purposes
Service mesh	A distributed computing middleware that optimizes communications between application services.	NIST SP 800-204A, Building Secure Microservices-Based Applications Using Service-Mesh Architecture
Service registration	The service registry service is used by microservices that are coming online to publish their locations in a process referred to as service registration and is used by microservices seeking to discover registered services.	NIST Glossary
	The process of microservices using the registry service to publish their locations when they come online. It is used by microservices seeking to discover other registered services.	FFIEC Adapted for Supervisory Purposes
Service registry	A directory where new service instances created for the microservices-based application register themselves while service instances going offline are deleted from it.	NIST SP 800-204A, Building Secure Microservices-Based Applications

Term	Definition	Source
		Using Service-Mesh Architecture
Shadow IT	Refers to unauthorized hardware and other devices, software, or services operating in an entity's IT environment.	FFIEC Developed for Supervisory Purposes
Signature	A recognizable, distinguishing pattern associated with an attack, such as a binary string in a virus or a particular set of keystrokes used to gain unauthorized access to a system.	NIST Glossary
Signature-based detection	This intrusion detection method compares network traffic to a set of pre-defined signatures and triggers an alert when a match is detected. Signatures are derived from numerous sources and are specific machine-readable patterns of network traffic that affect the integrity, confidentiality, or availability of computer networks, systems, and information.	DHS, Privacy Impact Assessment for the National Cybersecurity Protection System (NCPS) - Intrusion Detection
Single point of failure	An element in the design, configuration, or implementation of a system that can cause the entire system to fail if it stops working.	FFIEC Developed for Supervisory Purposes
Social engineering	The act of deceiving an individual into revealing sensitive information, obtaining unauthorized access, or committing fraud by associating with the individual to gain confidence and trust.	NIST Glossary
Software	Computer programs (which are stored in and executed by computer hardware) and associated data (which also is stored in the hardware) that may be dynamically written or modified during execution.	NIST Glossary
Software as a service (SaaS)	The capability provided to the consumer is to use the provider's applications running on a cloud infrastructure. The applications are accessible from various client devices through either a thin client interface, such as a web browser (e.g., web-based email), or a program interface. The consumer does not manage or control the underlying cloud infrastructure including network, servers, operating systems, storage, or even individual application capabilities, with the possible exception of limited user-specific application configuration settings.	NIST Glossary
Software bill of material (SBOM)	A formal record containing the details and supply chain relationships of various components used in building software. Software developers and vendors often create products by assembling existing open-source and commercial software components. The SBOM enumerates these components in a product.	NIST Glossary
Source code	Computer commands written in a computer programming language that is meant to be read by people.	U.S. Department of Commerce, "Open Source Code"
	Computer commands written in a computer programming language that is meant to be read by people. Source code is not executable by the computer directly. It must first be converted (e.g., via compiler, assembler) into a machine language.	FFIEC Adapted for Supervisory Purposes
Spiral model	The "Spiral" model divides a software development project into several smaller projects that address the major risks first.	NIST IR 7499, Guidelines for Planning and Development of Software for Buildings and Building Systems
	A risk-driven software development process model that divides a software development project into several smaller projects that address the major risks first. The model illustrates activities (e.g., requirements analysis, preliminary and detailed design, coding, integration, and testing) that are performed iteratively until development is complete.	FFIEC Adapted for Supervisory Purposes

Term	Definition	Source
Standard image	The approved set of server configurations, applications, and systems, which can be used to deploy servers consistently and rebuild them more easily and quickly, when necessary.	FFIEC Developed for Supervisory Purposes
Standards	Rules, conditions, or requirements describing the following information for products, systems, services or practices: (i) Classification of components. (ii) Specification of materials, performance, or operations; or (iii) Delineation of procedures.	NIST Glossary
State	A condition or mode of existence in which a system, component or simulation may be, e.g., the preflight state of an aircraft navigation program or the input state of a given channel.	ISACA Glossary
	A condition or mode of existence in which a system, component, or simulation (including stored data and inputs) may be at a given point in time.	FFIEC Adapted for Supervisory Purposes
Stateful	Refers to a data representation or a process that is dependent on an external data store.	NIST Glossary
	Refers to a data representation or a process that is dependent on some external information or other process and has the ability to retain or store the data for reuse.	FFIEC Adapted for Supervisory Purposes
Stateful inspection	Packet filtering that tracks the state of connections and blocks packets that deviate from the expected state.	NIST Glossary
Stateful protocol analysis	A firewalling capability that improves upon standard stateful inspection by adding basic intrusion detection technology. This technology consists of an inspection engine that analyzes protocols at the application layer to compare vendor-developed profiles of benign protocol activity against observed events to identify deviations, allowing a firewall to allow or deny access based on how an application is running over a network.	NIST Glossary
Stateless	Refers to a data representation or a process that is self-contained and does not depend on any external data store.	NIST Glossary
	Refers to a data representation or a process that is self-contained and does not depend on any external information or other process and it does not store or reuse data.	FFIEC Adapted for Supervisory Purposes
Statement of objective (SOO)	When the government is open to a wide range of solutions to meet their objective(s), it will use a SOO. You will need to develop and include in your offer a proposed PWS (i.e., your solutions), performance metrics, a measurement plan, and a quality assurance plan.	GSA
	When an entity is open to a wide range of solutions to meet their objective(s), it may use a SOO. You will need to develop and include in your offer a proposed PWS (i.e., your solutions), performance metrics, a measurement plan, and a quality assurance plan.	FFIEC Adapted for Supervisory Purposes
Statement of work (SOW)	A document that details the developer's responsibilities in the performance of the contract. Documentation developed under the contract, for example, is specified in the SOW. Security assurance requirements, which detail many aspects of the processes the developer follows and what evidence must be provided to assure the organization that the processes have been conducted correctly and completely, may be specified in the SOW.	NIST IR 7622, Notional Supply Chain Risk Management Practices for Federal Information Systems
Static analysis	Detecting software vulnerabilities by examining the app source code and binary code and attempting to reason over all possible behaviors that might arise at runtime. Also referred to as static testing.	NIST 800-163, rev. 1, Vetting the Security of Mobile Applications
Structured data	Data that has a predefined data model or is organized in a predefined way.	NIST SP 1500-1r2, NIST Big Data Interoperability Framework: Vol. 1, Definitions
Subcontractor	An individual or business firm contracting to perform part or all of another's contract.	Merriam-Webster

Term	Definition	Source
Supplier	Organization or an individual that enters into an agreement with the acquirer for the supply of a product or service.	NIST Glossary
	External or internal organization, business unit, or individual that enters into an agreement with the acquirer for the supply of a product, component, or service. This includes suppliers, developers, and manufacturers in the supply chain.	FFIEC Adapted for Supervisory Purposes
Supply chain	A system of organizations, people, activities, information, and resources, possibly international in scope, that provides products or services to consumers.	NIST Glossary
Supply chain risk management (SCRM)	The process of identifying, assessing, and mitigating the risks associated with the global and distributed nature of information and communications technology product and service supply chains.	NIST Glossary
	The process of identifying, assessing, and mitigating the risks interconnected throughout the supply chains and their components, such as susceptibilities, vulnerabilities, and threats, associated with the global and distributed nature of information and communications technology product and service supply chains.	FFIEC Adapted for Supervisory Purposes
System	A combination of interacting elements organized to achieve one or more stated purposes.	NIST Glossary
System and organization controls (SOC)	The suite of services CPAs may provide relating to system-level controls of a service organization and system- or entity-level controls of other organizations. Formerly, SOC referred to service organization controls. By redefining that acronym, the American Institute of Certified Public Accountants [AICPA] enables the introduction of new internal control examinations that may be performed (a) for other types of organizations, in addition to service organizations, and (b) on either system-level or entity-level controls of such organizations.	AICPA, System and Organization Controls: SOC Suite of Services
System development life cycle (SDLC)	The scope of activities associated with a system, encompassing the system's initiation, development and acquisition, implementation, operation and maintenance, and ultimately its disposal that instigates another system initiation.	NIST Glossary
System test	A test performed on a complete system to evaluate its compliance with specified requirements.	NIST Glossary
T		
Telecommunications	The transmission, between or among points specified by the user, of information of the user's choosing, without change in the form or content of the information as sent and received.	NIST Glossary
Term of support	The length of time for which the device will be supported by the manufacturer or supporting parties for such actions and materials as part replacements, software updates, vulnerability notices, technical support questions, etc.	NIST Glossary
	The length of time for which the software, hardware, or service will be supported by the manufacturer or supporting parties for such actions and materials as part replacements, software updates, vulnerability notices, and technical support questions.	FFIEC Adapted for Supervisory Purposes
Third-party service provider	Any independent party to whom an entity outsources activities that the entity itself is authorized to perform, including a technology service provider.	FFIEC Developed for Supervisory Purposes
Threat intelligence	Threat information that has been aggregated, transformed, analyzed, interpreted, or enriched to provide the necessary context for decision-making processes.	NIST Glossary
Threat model	A form of risk assessment that models aspects of the attack and defense sides of a logical entity, such as a piece of data, an application, a host, a system, or an environment.	NIST Glossary
Transmission	An act, process, or instance of transmitting.	Merriam-Webster
	The act of sending or conveying data, voice, audio, or video from one person or place to another.	FFIEC Adapted for Supervisory Purposes

Term	Definition	Source
U		
Unit testing	A testing technique that is used to test program logic in a particular program or module. The purpose of the test is to ensure that the internal operation of the program performs according to specification. It uses a set of test cases that focus on the control structure of the procedural design.	ISACA Glossary
Unstructured data	Data that does not have a predefined data model or is not organized in a predefined way.	NIST SP 1500-1r2 , NIST Big Data Interoperability Framework: Vol. 1, Definitions
Useful life	The normal expected operating life of an asset.	Internal Revenue Service
User acceptance testing (UAT)	Testing that involves taking use cases or procedures for how the system was designed to perform and ensuring that someone who follows the procedure gets the intended result; however, it does not necessarily demonstrate how well the system supports users in performing those functions.	NIST IR 7741 , NIST Guide to the Processes Approach for Improving the Usability of Electronic Health Records
V		
Virtualization	The simulation of the software and/or hardware upon which other software runs.	NIST Glossary
Virtual machine (VM)	Software that allows a single host to run one or more guest operating systems.	NIST Glossary
	A simulated environment created by virtualization using software that allows a single host to run one or more guest operating systems.	FFIEC Adapted for Supervisory Purposes
Vulnerability	Weakness in system security procedures, design, implementation, internal controls, etc., that could be accidentally triggered or intentionally exploited and result in a violation of the system's security policy.	NIST Glossary
Vulnerability assessment	Systematic examination of an information system or product to determine the adequacy of security and privacy measures, identify security and privacy deficiencies, provide data from which to predict the effectiveness of proposed security and privacy measures, and confirm the adequacy of such measures after implementation.	NIST Glossary
Vulnerability management	The practice of identification, classification, remediation, and mitigation of vulnerabilities in systems, subsystems, and system components.	DoD Instruction 8531.01 ; DoD Vulnerability Management
Vulnerability scanning	A technique used to identify hosts/host attributes and associated vulnerabilities.	NIST Glossary
W		
Workstation	A computer used for tasks such as programming, engineering, and design.	NIST Glossary
Z		
Zero-day exploit	Referred to as zero-day attack; an attack that exploits a previously unknown hardware, firmware, or software vulnerability.	NIST Glossary
	An exploit that exploits a previously unknown hardware, firmware, or software vulnerability.	FFIEC Adapted for Supervisory Purposes

APPENDIX C: ABBREVIATIONS

AI	artificial intelligence
AICPA	American Institute of Certified Public Accountants
API	application programming interface
ATM	automated teller machine
CA	Consumer Affairs (for FRB SR Letters)
CCB	configuration or change control board
CD	continuous delivery
CFPB	Consumer Financial Protection Bureau
CFR	Code of Federal Regulations
CI	continuous integration
CIO	chief information officer
CISA	Cybersecurity and Infrastructure Security Agency
CISO	chief information security officer
COTS	commercial off-the-shelf
CPU	central processing unit
DevOps	development and operations
DevSecOps	development security operations
DOD	Department of Defense
EOL	end-of-life
EULA	end user license agreement
FDIC	Federal Deposit Insurance Corporation
FFIEC	Federal Financial Institutions Examination Council
Fintech	financial technology
FOSS	free and open-source software
FIL	Financial Institution Letter
FRB	Board of Governors of the Federal Reserve System
FS-ISAC	Financial Services Information Sharing and Analysis Center
FTC	Federal Trade Commission
GLBA	Gramm–Leach–Bliley Act
GSA	U.S. General Services Administration
HVAC	heating, ventilation, and air conditioning
IaaS	infrastructure-as-a-service
IoT	internet of things
IR	Internal Report
ISACA	Information Systems Audit and Control Association
ISAC	information sharing and analysis center
IT	information technology
ITAM	IT asset management
ITL	Information Technology Laboratory
ITRM	IT risk management
FFIEC IT Handbook	FFIEC Information Technology Examination Handbook
MFA	multifactor authentication
MSA	master services agreement
NCUA	National Credit Union Administration

NIST	National Institute of Standards and Technology
NTIA	National Telecommunications and Information Administration
OCC	Office of the Comptroller of the Currency
OEM	original equipment manufacturer
OFAC	Office of Foreign Assets Control
OWASP	Open Worldwide Application Security Project
OS	operating system
PaaS	platform-as-a-service
PIR	post-implementation review
PMI	Project Management Institute
PMO	program management office
PWS	performance work statement
QA	quality assurance
QC	quality control
RAM	random access memory
RFI	request for information
RFID	radio frequency identification
RFP	request for proposal
RFQ	request for quote
SaaS	software-as-a-service
SBOM	software bill of material
SCRM	supply chain risk management
SDLC	system development life cycle
SLA	service-level agreement
SLC	State Liaison Committee
SOC	security operations center
SOC	system and organization control
SOW	statement of work
SP	Special Publication
SQL	Structured Query Language
SR	Supervision and Regulation Letter
UAT	user acceptance testing
USB	universal serial bus
USC	U.S. Code

APPENDIX D: REFERENCES

Laws

- 11 USC 101–112, “[Bankruptcy](#)” and “[Office of the Law Revision Counsel: U.S. Code; Title 11](#)”
- 12 USC 226, “[Title X of the Financial Institutions Regulatory and Interest Rate Control Act of 1978](#)”
- 12 USC 1461–1468, “[Home Owners’ Loan Act](#)”
- 12 USC 1813.3(u), “[Institution-Affiliated Party](#)”
- 12 USC 1841–1852, “[Bank Holding Company Act](#)”
- 12 USC 1861–1867, “[Bank Service Company Act](#)”
- 12 USC 1882, “[Bank Protection Act of 1968](#)”
- 12 USC 5481(14) and (26), 5514, 5515, and 5531, “[Dodd–Frank Wall Street Reform and Consumer Protection Act](#)”
- 15 USC 1681w, “[Fair and Accurate Credit Transactions Act](#)”
- 15 USC 6801–6809 and 6821–6827, “Financial Modernization Act of 1999” (“[Gramm–Leach–Bliley Act](#)” [GLBA])
- 17 USC 1–8, 10–12, “[Copyright Law of the United States](#)”
- 18 USC 1030, “[Fraud and Related Activity in Connection With Computers](#)”
- 29 USC 794d, “[Rehabilitation Act of 1973, Section 508](#)”

Consumer Financial Protection Bureau

Regulations

- 12 CFR 1005, “[Electronic Fund Transfers \(Regulation E\)](#)”
- 12 CFR 1016, “[Privacy of Consumer Financial Information \(Regulation P\)](#)”
- 12 CFR 1022, “[Fair Credit Reporting Act \(Regulation V\)](#)”

Guidance

CFPB Compliance Bulletin and Policy Guidance 2016-02, “[Service Providers](#)” (October 2016)

Federal Deposit Insurance Corporation

Regulations

- 12 CFR 304.3(d), “[Notification of Performance of Bank Services, Form FDIC 6120/06](#)”
- 12 CFR 326, subpart A, “[Minimum Security Procedures](#)”
- 12 CFR 332, “[Privacy of Consumer Financial Information](#)”
- 12 CFR 364, appendix A, “[Interagency Guidelines Establishing Standards for Safety and Soundness](#)”

- 12 CFR 364, appendix B, “[Interagency Guidelines Establishing Information Security Standards](#)”
- 12 CFR 364, supplement A to appendix B, “[Interagency Guidance on Response Programs for Unauthorized Access to Customer Information and Customer Notice](#)”

Guidance

- FIL-29-2023, “[Interagency Guidance on Third-Party Relationships: Risk Management](#)” (June 6, 2023)
- FIL-10-2023, “[Financial Institutions Are Required to Meet Contractual Obligations With Bridge Banks](#)” (March 14, 2023)
- FIL-08-2023, “[Joint Statement on Liquidity Risks to Banking Organizations Resulting From Crypto-Asset Market Vulnerabilities](#)” (February 23, 2023)
- FIL-01-2023, “[Joint Statement on Crypto-Asset Risks to Banking Organizations](#)” (January 5, 2023)
- FIL-35-2022, “[Advisory to FDIC-Insured Institutions Regarding Deposit Insurance and Dealings With Crypto Companies](#)” (July 29, 2022)
- FIL-30-2022, “[FDIC Updates on Brokered Deposits](#)” (July 15, 2022)
- FIL-16-2022, “[Notification of Engaging in Crypto-Related Activities](#)” (April 7, 2022)
- FIL-12-2022, “[Computer-Security Incident Notification Implementation](#)” (March 29, 2022)
- FIL-74-2021, “[Computer-Security Incident Notification Final Rule](#)” (November 18, 2021)
- FIL-59-2021, “[Conducting Due Diligence on Financial Technology Companies: A Guide for Community Banks](#)” (August 27, 2021)
- FIL-55-2021, “[Authentication and Access to Financial Institution Services and Systems](#)” (August 11, 2021)
- FIL-27-2021, “[Bank Secrecy Act: Agencies Address Model Risk Management for Bank Models and Systems Supporting Bank Secrecy Act/Anti-Money Laundering and Office of Foreign Assets Control Compliance](#)” (April 9, 2021)
- FIL-103-2020, “[The FDIC Publishes Sound Practices to Strengthen Operational Resilience](#)” (November 2, 2020)
- FIL-52-2020, “[FFIEC Joint Statement on Risk Management for Cloud Computing Services](#)” (April 30, 2020)
- FIL-14-2020, “[Interagency Statement on Pandemic Planning](#)” (March 6, 2020)
- FIL-19-2019, “[Technology Service Provider Contracts](#)” (April 2, 2019)
- FIL-16-2018, “[FFIEC Issues Joint Statement: Cyber Insurance and Its Potential Role in Risk Management Programs](#)” (April 10, 2018)
- FIL-68-2016, “[FFIEC Cybersecurity Assessment Tool: Frequently Asked Questions](#)” (October 18, 2016)
- FIL-43-2016, “[Information Technology Risk Examination \(InTREx\) Program](#)” (June 30, 2016)
- FIL-37-2016, “[FFIEC Joint Statement on Cybersecurity of Interbank Messaging and Wholesale Payment Networks](#)” (June 7, 2016)
- FIL-28-2015, “[Cybersecurity Assessment Tool](#)” (July 2, 2015)
- FIL-13-2015, “[FFIEC Joint Statements on Destructive Malware and Compromised Credentials](#)” (March 30, 2015)